DAT158

AI – Phishing detector

Kasper Austbø, Elida Risberg Elverum, Andreas Dahl Kaartinen, 05.10.2026

Innhold

DAT158 1
1: BESKRIV PROBLEMET 2
OMFANG / SCOPE 2
Systemet som del av en større pipeline 2
Lønnsomhet 2
Utviklere 3
METRIKKER 3
2: DATA 5
Data og labels 5
Datasett og estimert behov 5
Innsamling og kvalitetssikring av labels 5
Personvernhensyn og etikk 5
Datarepresentasjon, rensing og feature engineering 6
3: MODELLERING 6
4: DEPLOYMENT 9
Hvordan settes modellen i drift? 9
Bruk av prediksjoner 9
Monitorering og vedlikehold 9
5: REFERANSER 10

1: BESKRIV PROBLEMET

OMFANG / SCOPE

Phishing er en form for digital svindel hvor angripere prøver å lure mottaker til å oppgi sensitiv informasjon, trykke på skadelige lenker eller laste ned skadelig programvare. Denne typen angrep kan føre til store problemer både for privat personer, men også bedrifter. Derfor er det viktig at slike angrep blir oppdaget tidlig før de fører til større skade.

Målet med prosjektet vårt er å utvikle en maskinlæringsbasert phishing-detektor som kan analysere eposter og merke de som enten legitime eller mulige phishing forsøk. Modellen skal innlemmes i en nettside hvor brukeren kan lime inn innholdet i en epost og få en vurdering om eposten er trygg eller ikke. På lengre sikt ser vi for oss at dette mulig kan være en løsning vi kan selge til bedrifter for å sikre at deres ansatte ikke trykker på farlige lenker. Produktet frigir tid hos ansatte ved at de slipper å bruke tid selv på å vurdere om en e-post er reell og minimere sjansen for dataangrep.

Systemet som del av en større pipeline

Dersom vi tar modellen videre og ut i kommersiell bruk ser vi for oss at modellen vil være en del av en Outlook plugin som en løsning vi selger til bedrifter. Systemet vil da fungere ved at en epost først mottas av epost serveren før det går videre til datarensing. Her blir relevant informasjon som tekst, avsender og lenker hentet ut, samtidig som unødvendig html kode fjernes. Den ferdigrensede dataen kjøres gjennom maskinlæringsmodellen vår som gir ut et svar på sannsynligheten for at det er en phishing e-post. Systemet vil bruke forhåndsbestemte regler for å avgjøre hvilke eposter som skal markeres som potensielle phishing forsøk. I Outlook utvidelsen vil de ansatte få opp en rød merking på eposter som ser ut til å være phishing.

Lønnsomhet

Lønnsomheten og verdien i systemet måles gjennom unngåtte kostnader. Dette vil være return of investment(ROI) som kan beregnes ut ifra hvor mye penger den enkelte bedrift

sparer på å forhindre nedetid, unngå utbetaling av løsepenger til aktører, samt at de slipper unna bøter hvis det skulle oppstå en datalekkasje. Bedriften kan også tape penger om filteret er for strengt, og ikke slipper gjennom legitime eposter fra kunder, kontrakter eller fakturaer. Kostnaden av tap må derfor nøye balanseres mot sikkerhetsgevinsten.

Utviklere

For utvikling kreves datamaskiner med tilstrekkelig minne og prosessorkraft for å trene modellen. Siden det brukes TF-IDF og logisk regresjon er treningskostandene relativt lave sammenlignet med andre kraftfulle og dyre modeller. Hvis man skulle brukt det som en hjemmeside, og ikke som en plugin er det behov for en skyløsning, for eksempel AWS eller Azure. Driftskostnadene vil påvirkes sterkt av størrelsen på bedriften og epost volumet. Det vil være behov for utviklere som kan jobbe med maskinlæring for dataprosessering, trening av modellen og tune parameterne. Det vil også være behov for utviklere som kan integrere modellen i eksisterende infrastruktur. Bedriften vil også trenge en sikkerhetsanalytiker som må overvåke systemet, og manuelt kan sjekke feil eposter og oppdatere datasettet.

METRIKKER

For at prosjektet skal være en suksess må pengene en bedrift sparer på arbeidstid til ansatte, løspengekrav, nedetid og GDPR bøter være betydelig mye større enn hva kostnaden for å utvikle og trene maskinlæringsmodellen er.

For å måle hvor godt modellen fungerer bruker vi accuracy, precision, recall og F1-score. Datasettet deles inn i 80% treningsdata og 20% testdata for å evaluere modellen. Accuracy viser hvor stor andel av alle epostene som klassifiseres riktig, mens precision viser hvor stor andel av epostene som kategoriseres som phishing, som faktisk tilhører denne kategorien, recall viser hvor stor andel av phishing e-postene modellen klarer å oppdage, mens F1-score måler balansen mellom precision og recall.

Applikasjonen viser modellens estimerte sannsynlighet for at eposten er phishing som en prosentverdi, deretter kategoriserer de i lav, mulig eller høy risiko basert på de

forhåndsbestemte grenseverdiene. Høy recall er viktig for å oppdage flest mulig phishing forsøk, mens høy precision bidrar til å unngå unødvendige advarsler om reelle eposter.

2: DATA

Data og labels

Problemet krever håndtering av primært ustrukturert tekstdata (Natural Language Processing), der det brukes sender_email(avsenderadresse), subject (emnefelt) og emailbody(innholdet). For å klassifisere hva som er en trygg epost og hva som er en farlig epost, benyttes binære labels. Hver epost i datasettet blir tilordnet en label som enten er Phishing(1) eller Legitim (0).

Datasett og estimert behov

I denne oppgaven er dataene hentet fra Kaggle-settet Phishing Email Detection Dataset, som er et ferdig datasett i CSV format. Settet består av 50 000 eposter. Datasettet har innhentet flere eposter fra anerkjente offentlige arkiver, fra for eksempel Enron, PhishTank og Spam Assistant for farlige eposter.

Dersom vi skulle samlet opp datagrunnlag for et reelt produksjonsmiljø, ville vi nok brukt data som samles inn kontinuerlig gjennom bedriften. Dette kunne vi gjort gjennom et spamfilter, kobles opp mot globale apier som deler eposter, eller via systemer internt der ansatte kan rapportere og sende inn eposter som er mistenkelige.

Innsamling og kvalitetssikring av labels

Dersom vi skulle hente inn og merke ny data, vil det kreve en todelt tilnærming for å sikre kvaliteten. Åpenbare svindelforsøk merkes automatisk, dette kan for eksempel være svartlistende domener. Vi tenker også at eposter der systemet er usikkert, vil en sikkerhetsanalytiker kunne sjekke om eposten er falsk eller ekte. Det må etableres strenge retningslinjer for hva som defineres som phishing kontra reklame eposter. Det er også mulig å etablere et system der man bruker flertall av avgjørelse, hvor flere uavhengige vurderer samme epost.

Personvernhensyn og etikk

Bruk av epostdata krever betydelig personvernhensyn og etiske betraktinger. Dette fordi eposter nesten alltid sendes med sensitiv data, som navn, adresser, telefonnummer og annet sensitivt innhold. Vi er også nødt til å følge lovverk som GDPR, og vi er derfor nødt til å anonymisere før det brukes til modelltrening. Vi er også nødt til å ta høyde for falske

positive, altså at informasjon som er viktig havner i spamfilteret. Vi er også nødt til å ta høyde for at eposter skrevet på dårlig engelsk (evt norsk), kan bli filtrert bort.

Datarepresentasjon, rensing og feature engineering

Rensing av data skjer ved at det først fjernes rader som mangler labels. Tomme tekstfelt fylles med tomme strenger, teksten standardiseres til små bokstaver. Deretter fjernes duplikater for at modellen ikke tilpasses samme epost.

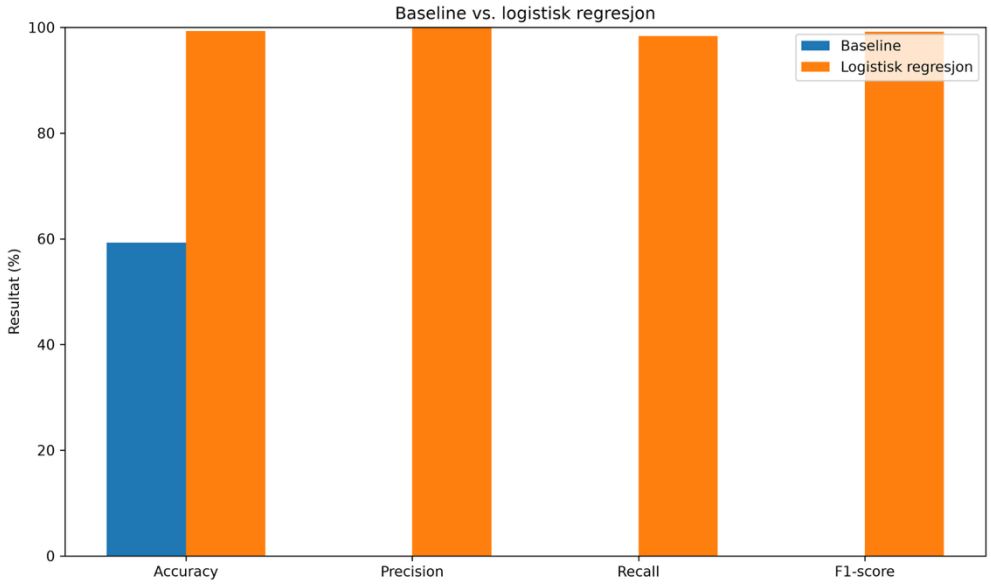
Vi slår sammen emnefeltet og innholdet til en felles tekst feature, dette gjør at den blir en egen feature. Avsenderen er en egen feature som kan brukes for å finne spesifikke domener som virker falske.

Avsenderadressen sjekkes på tegnnivå for skrivefeil i falske domener, mens innholdet i hver epost sjekkes på ord nivå. Vi bruker TF-IDF metoden som sikrer at modellen vurderer ordene uavhengig av epostens totale lengde.

3: MODELLERING

Til phishing-detektoren valgte vi å bruke logistisk regresjon. Dette er en modell som passer godt til å skille mellom to kategorier, i vårt tilfelle legitime e-poster og phishing. Vi bruker TF-IDF for å gjøre teksten i e-postene om til tall som modellen kan lære av. Datasettet ble delt inn i 80 % treningsdata og 20 % testdata. Vi brukte også

GridSearchCV for å finne den beste verdien for parameteren C, som ble 0,1.

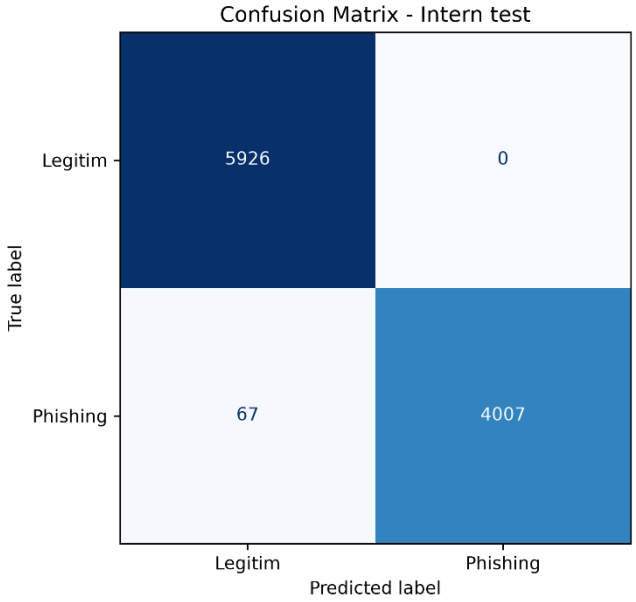


Figur 1: Sammenligning av resultatene fra baseline og den trente modellen.

For å se hvor godt modellen fungerer, sammenlignet vi den med en enkel baseline som alltid klassifiserer e-poster som legitime. Denne fikk 59,26 % accuracy, men klarte ikke å oppdage noen phishing-eposter. Dette viser at en modell kan få relativt høy accuracy uten å være spesielt nyttig til å oppdage svindelforsøk.

Den trente modellen fikk betydelig bedre resultater med 99,33 % accuracy, 100 % precision, 98,36 % recall og 99,17 % F1-score på testsettet med 10 000 e-poster.

For å undersøke resultatene nærmere brukte vi en confusion matrix, som viser hvor mange e-poster modellen klassifiserte riktig og feil.



Figur 2: Oversikt over riktige og feilaktige klassifiseringer.

Resultatene viser at modellen klassifiserte 5 926 legitime e-poster og 4 007 phishing-eposter riktig. Ingen legitime e-poster ble feilaktig merket som phishing, men 67 phishing-eposter ble klassifisert som legitime. Dette er en svakhet ved modellen, siden slike feil kan føre til at brukeren stoler på en e-post som egentlig er farlig.

Vi undersøkte også hvilke ord som påvirket modellens vurderinger mest. Ord som «expires», «immediate» og «verification» trakk vurderingen mot phishing, mens blant annet «been» og «has been» trakk den mot legitim e-post. Dette viser at modellen har lært å kjenne igjen ulike mønstre i teksten.

Selv om modellen fikk gode resultater på testsettet, betyr ikke dette at den vil oppdage alle phishing-forsøk. Svindelmetoder endrer seg stadig, og modellen kan derfor ha behov for å trenes på nyere e-poster for å opprettholde treffsikkerheten.

4: DEPLOYMENT

https://machine-learning-software.onrender.com/

Hvordan settes modellen i drift?

Modellen og brukergrensesnittet er satt i drift via skytjenesten Render.com som er koblet direkte mot prosjektets GitHub repository. Hver gang vi pusher til main branchen bygger Render automatisk siden på nytt, den installerer avhengighetene, laster inn den ferdig trente modellen og starter webserveren via app.py.

Bruk av prediksjoner

Brukeren legger inn e-post med avsender, emne og innhold og modellen bruker dette til å beregne en sannsynlighetsscore (0 – 1). Prediksjonene klassifiseres basert på forhåndsbestemte risikoterskler. Med en sannsynlighetsscore over 0,75 vil brukeren få beskjed om at det er høy sannsynlighet for phishing og at e-posten inneholder sterke tegn på svindelforsøk. Ved en sannsynlighetsscore mellom 0,4 og 0,74 vil brukeren bli varslet om at det er mulig risiko, da e-posten inneholder enkelte kjennetegn på svindelforsøk. Hvis sannsynlighetsscoren er under 0,4 blir brukeren varslet om lav risiko og e-posten fremstår legitim.

Monitorering og vedlikehold

Ved reel utrulling av modellen vil det kreve en del vedlikehold og monitorering. Gitt at phishing angripere hele tiden bytter mønstre, endrer emne og språkbruk for å omgå phishing filtre må vi overvåke modellen for fall i nøyaktighet over tid. Vi må også etablere rutiner for å registrere og logge tilfeller av feilklassifisering, både falske positiver og falske negativer. Ideelt skal modellen re-trenes med jevne mellomrom på nye datasett som inneholder ferske eksempler på phishingangrep.

5: REFERANSER

List opp kilder du har brukt til å utarbeide prosjektbeskrivelsen.

- https://www.datatilsynet.no/regelverk-og-verktoy/lover-og-regler/om-personopplysningsloven-og-nar-den-gjelder/ (13/10 2026)
- https://www.kaggle.com/datasets/mobeenfatimah/phishing-email-detection-dataset-50k-emails (7/10 2026)
- https://machine-learning-software.onrender.com/
- https://zenodo.org/records/18471483 (12/10 2026)
- https://github.com/SunnyThakur25/Phishing-Benign-Email-Dataset-Short-Version- (12/10 2026)